Threat Intel Briefs - Alexander Palacios

I created three threat intel briefs for ITN 260 at NOVA. Two of them cover 2024-2025 breaches, and one covers a currently exploited CVE. Each brief goes through a summary, timeline, attacker methods mapped to MITRE ATT&CK, indicators, impact, recommendations, and Splunk searches I wrote to detect the attack.

Brief 1: PowerSchool data breach (Dec 2024)

Summary: One stolen support credential with no MFA, and a culprit exported student and teacher information from individual school district SISes through PowerSchool's customer support portal, PowerSource. Information of some 60M students and 10M teachers in the US and Canada was stolen in the end, and, after PowerSchool paid the hackers $2.9M in ransom, the same individuals started demanding money from the individual school districts' administrators as well.

Severity: Critical Sector: K-12 education / EdTech SaaS Actor: Matthew Lane (sentenced Oct 2025) and co-conspirators Motive: Financial extortion

What happened

- PowerSchool runs a Student Information System (SIS) used by 18,000+ customers.
- The attacker logged into PowerSource, PowerSchool's customer support portal, using a contractor/support account's credentials.
- From PowerSource the attacker ran "Maintenance Remote Support" sessions into individual district SIS instances. He then used the built-in export data manager in the SIS to export the Students and Teachers tables.
- Stolen information contained: names, contacts, dates of birth, Social Security Numbers, and several categories of medical alerts. Much academic information was included as well. Decades of historical academic information was compromised at several school districts, including the TDSB (information went back to 1985).
- CrowdStrike forensics found that the same stolen credential was used to log into PowerSource in Aug-Sep 2024, months prior to discovery of the breach.

Timeline

- Aug 16 - Sept 17, 2024: Earlier access to PowerSource with the same credential
- Dec 19, 2024: Attacker logs into PowerSource (19:43 UTC)

- Dec 22, 2024: Data exfiltration starts
- Dec 28, 2024: PowerSchool detects the breach and disables the credential
- Jan 7, 2025: PowerSchool notifies customers
- Mar 2025: PowerSchool publishes CrowdStrike forensic report
- May 2025: Lane pleads guilty; districts in the US and Canada start getting extortion demands with the "deleted" data
- Oct 2025: Lane sentenced to 4 years, ~$14.1M restitution

MITRE ATT&CK mapping

- Initial Access, T1078 Valid Accounts: logged in with a real support credential
- Persistence, T1078 Valid Accounts: same credential reused Aug, Sept, and Dec 2024
- Collection, T1213 Data from Information Repositories: exported Students/Teachers tables via export data manager
- Exfiltration, T1048 Exfiltration Over Alternative Protocol (likely; exact method not disclosed): records moved to a leased server in Ukraine
- Impact, T1657 Financial Theft: ransom from PowerSchool, then from districts

Indicators

PowerSchool only released a very small set of network-level IOCs, so detection is mostly behavioral.

- PowerSource support account logins from new IPs, countries, or odd hours
- "Maintenance Remote Support" sessions nobody opened a ticket for
- Large export data manager jobs on the Students or Teachers tables
- Large outbound transfers to hosting providers shortly after "Maintenance Remote Support" sessions

Impact

- The breach has reportedly been classified as the largest schoolchildren data breach in the US to date.
- Minors' SSNs and medical information stolen, creating lifelong identity theft risk.
- PowerSchool: ~$14M+ in losses. Texas AG suing PowerSchool in a Sept 2025 lawsuit. Multiple class actions.

- Paying the ransom didn't work, as data hasn't been deleted but rather used against additional school districts.

Recommendations

1. Require MFA on all accounts (vendor/support portal login accounts) that can access customer data.
2. Limit support accounts to just-in-time access tied to an open ticket.
3. Send an alert when someone attempts a large export and require approval prior to sending out.
4. Districts: ask vendors how their support staff access your data before signing.
5. Don't assume paying the ransom will eliminate risk to your data.

Splunk searches

Searches I developed to identify PowerSchool/SIS activity in the app and auth logs.

```
index=auth app="PowerSource" action=success
| iplocation src_ip
| stats count dc(src_ip) AS unique_ips values(Country) AS countries BY user
| where unique_ips > 3
```

```
index=app sourcetype=sis_audit action="export" table IN
("Students","Teachers")
| bin _time span=1h
| stats sum(record_count) AS records BY user, _time
| where records > 10000
```

Sources: SecurityWeek, BleepingComputer (CrowdStrike report), TechTarget, CyberScoop (sentencing), BleepingComputer (sentencing), SecurityWeek (sentencing)

Brief 2: Oracle Cloud login server breach (Mar 2025)

Summary: A threat actor claims to have exfiltrated 6M records of user login credentials for SSO and LDAP servers for Oracle Cloud SaaS offerings, affecting over 140,000 Oracle Cloud tenants. Although Oracle denied the hack, it later notified customers of access to 2 "obsolete" legacy servers. The data, some 6M lines (encrypted/hashed passwords for SSO

and LDAP logins, Java Keystore (JKS) files, key files, and Enterprise Manager JPS keys), has been put up for sale by the seller known as "rose87168" on BreachForums. CISA published guidance relating to credential risk on April 16, 2025.

Severity: High Sector: Cloud / supply chain Actor: rose87168 (BreachForums seller, unattributed) Motive: Financial (data sale, extortion)

What happened

- The attacker claims to have compromised login.us2.oraclecloud.com (a production SSO endpoint running the old Oracle Fusion Middleware 11G codebase).
- As CloudSEK's researchers speculate, the vulnerability most likely used here is CVE-2021-35587, an unauthenticated Remote Code Execution (RCE) bug rated CVSS 9.8 in Oracle Access Manager (which is built upon OpenSSO Agent). The seller hints at a completely different unknown vulnerability being used to breach the environment.
- The threat actor offered for sale the following data from Oracle Cloud in encrypted/hashed format: SSO and LDAP passwords, Java Keystore (JKS) files, key files, Enterprise Manager JPS keys. 6M lines of data in total were offered for sale.
- The threat actor uploaded a file containing their ProtonMail email address to the compromised server in order to prove access. That file has been archived by the Wayback Machine.
- Researchers were able to match several of the customer domains to the attacker's tenant list.

Timeline

- Late 2024: Earliest data the actor shared with reporters
- Feb 2025: Intrusion reportedly discovered
- Mar 20, 2025: rose87168 posts 6M records + 140k tenants on BreachForums
- Mar 21, 2025: CloudSEK publishes analysis; Oracle publicly denies a breach
- Apr 7, 2025: Oracle notifies customers that two legacy servers were accessed but maintains that no breach occurred on Oracle Cloud Infrastructure (OCI)
- Apr 16, 2025: CISA releases guidance on credential risks from the legacy Oracle Cloud compromise

MITRE ATT&CK mapping

- Initial Access, T1190 Exploit Public-Facing Application: likely CVE-2021-35587 on the SSO login server
- Credential Access, T1552.004 Unsecured Credentials: Private Keys: JKS files and key files taken
- Credential Access, T1005 Data from Local System: hashed SSO and LDAP passwords pulled
- Exfiltration, T1048 Exfiltration Over Alternative Protocol (likely; exact method not disclosed): ~6M records taken off the server
- Impact, T1657 Financial Theft: data sold or traded for zero-days; tenants asked to pay for removal

Indicators

- Host: login.us2.oraclecloud.com (and the login.(region).oraclecloud.com pattern)
- Vulnerability: CVE-2021-35587 in Oracle Access Manager / Fusion Middleware 11G
- Actor handle: rose87168 (BreachForums), ProtonMail contact
- Behavioral: Oracle Cloud SSO authentication from new devices or new IP addresses after March 2025; use of passwords that were never rotated

Impact

- 140,000+ tenants potentially exposed according to the actor's list; this has not been verified by Oracle.
- Stolen keys and passwords can be cracked or reused on other systems, which is CISA's biggest concern.
- Damaged trust: a 2021 vulnerability in a legacy system was not supposed to hurt anymore, but it did, contrary to Oracle's denials, as shown by researchers' evidence and Oracle's own later notice.
- Class-action lawsuits followed.

Recommendations (from CISA's guidance)

1. Reset passwords for any affected end-users and any local accounts that are not tied to enterprise SSO.
2. Look for hardcoded login information in your code and configuration files and change them.

3. Enforce phishing-resistant MFA on all user and admin accounts.
4. Monitor for authentication anomalies.
5. Legacy middleware (for example, a 2021 CVE) should not still be exploitable on a production login server; it should be retired or patched.

Splunk searches

Searches I wrote to detect attempts to exploit the SSO server and suspicious login activity after the breach.

```
index=web sourcetype=access_combined host="login*.oraclecloud.com"
method=POST
| search uri_path="*/oam/server/*" OR uri_path="*opensso*"
| stats count BY src_ip, uri_path, status
```

```
index=auth app="OracleSSO" action=success
| stats earliest(_time) AS first_seen latest(_time) AS last_seen dc(src_ip)
AS ips BY user
| where first_seen > relative_time(now(), "-30d") AND ips > 2
```

Sources: eSecurity Planet, SOCRadar, Arctic Wolf, Data Privacy & Security Insider, ABA Health Law, CISA alert

Brief 3: SAP NetWeaver Visual Composer - CVE-2025-31324

Summary: CVE-2025-31324 is a missing-authorization CVSS 10.0 bug in SAP NetWeaver Visual Composer that allows anyone to upload any file without login. It has been exploited as a zero-day to upload JSP webshells to end up with full remote code execution on SAP application servers. This bug has been exploited by China-nexus APT groups as well as by ransomware crews.

Severity: Critical (CVSS 10.0) Affected: SAP NetWeaver 7.xx with Visual Composer Actors: UNC5221, UNC5174, CL-STA-0048 (China-nexus), plus ransomware operators Motive: Espionage and financial

What happened

- The bug is located in the endpoint /developmentserver/metadatauploader. It is missing the authorization check.
- Attackers send a crafted HTTP POST with a JSP webshell set as the "metadata" file.

- The JSP webshell is uploaded to /j2ee/cluster/apps/sap.com/irj/servletjsp/irj/root/ as a "metadata" file, then a GET request runs the webshell.
- The attacker executes commands, uploads additional malicious tools and continues to spread within the internal network from the JSP based webshell.
- Attacks using this exploit were seen as early as March 27, 2025, mostly against organizations in the manufacturing space, according to Rapid7. ~450 vulnerable systems were found exposed to the internet by the nonprofit Shadowserver.

Timeline

- Mar 27, 2025: Earliest exploitation seen by Rapid7
- Mid-Apr 2025: Exploitation seen in multiple customer environments
- Apr 22, 2025: ReliaQuest conducts investigation and reports the vulnerability to SAP
- Apr 24, 2025: SAP releases emergency patch
- Apr 25, 2025: Onapsis and others confirm active exploitation of SAP NetWeaver; Onapsis provides a free scanner to identify affected systems
- May 2025: EclecticIQ links the attacks to China-nexus APT groups targeting critical national infrastructure in the USA, UK and Saudi Arabia

MITRE ATT&CK mapping

- Initial Access, T1190 Exploit Public-Facing Application: POST to /developmentserver/metadatauploader
- Persistence, T1505.003 Web Shell: JSP webshells in the irj/root directory
- Execution, T1059 Command and Scripting Interpreter: commands run through webshell GET requests
- Command and Control, T1105 Ingress Tool Transfer: extra payloads uploaded through the webshell
- Lateral Movement, T1021 Remote Services: pivoting from SAP into the wider network

Indicators

- URI: /developmentserver/metadatauploader (any POST from outside is suspicious)
- New .jsp, .java, or .class files in ...\irj\servletjsp\irj\root\ or ...\irj\servletjsp\irj\work\
- Reported webshell names: helper.jsp, cache.jsp and other random 8-character .jsp files
- Child processes such as cmd.exe, powershell or sh that were spawned by the SAP Java server (jstart.exe)

Impact

- Full control of SAP servers, which hold finance, supply chain, and HR data
- Manufacturing and critical infrastructure were the main targets
- So easy to exploit (no login required) that public scanning started fast

Recommendations

1. Apply SAP's patch for CVE-2025-31324 right away.
2. Disable Visual Composer or block /developmentserver/metadatauploader on the firewall/WAF.
3. Search irj/root and irj/work directories for unknown .jsp files even after patching. Patching does not remove webshells from already compromised systems.
4. Use the Onapsis open-source scanner to inspect your SAP application for known webshells and webshell exposure, even after patching.
5. Keep SAP systems off the open internet where possible.

Splunk searches

Searches I built to detect exploit attempts, webshell access and additional commands spawned by the SAP server.

```
index=web uri_path="*/developmentserver/metadatauploader*" method=POST
| stats count earliest(_time) AS first_seen BY src_ip, status,
http_user_agent
| sort - count
```

```
index=web uri_path="*/irj/*.jsp" method=GET
| rex field=uri_path "(?<jsp_file>[^/]+\.jsp)$"
| stats count dc(src_ip) AS ips BY jsp_file
| where ips < 3
```

```
index=endpoint sourcetype=sysmon EventCode=1 ParentImage="*jstart.exe"
| search Image IN ("*cmd.exe","*powershell.exe")
| table _time host ParentImage Image CommandLine
```

Sources: ReliaQuest via Kudelski Security, Help Net Security, Security Affairs, GovInfoSecurity, Palo Alto Networks, SOC Prime / EclecticIQ